

Narrativa Explicativa de la Encuesta GRC

1. Una encuesta, tres letras y un país conectado

GRC. Tres letras discretas que en las presentaciones de los consejos se adornan con flechas, iconos y degradados de color, pero que en la vida real deciden si una organización sobrevive con dignidad a un ciberataque o si acaba en los titulares por las razones equivocadas. La encuesta que tienes entre manos pretende, modestamente, poner algo de orden en ese ecosistema de buenas intenciones y sustos periódicos.

El objetivo no es exhibir una colección de preguntas para torturar CISOs, sino construir un espejo razonablemente honesto del estado de la gobernanza, el riesgo y el cumplimiento en la ciberseguridad de las organizaciones que operan en España. Y hacerlo con un lenguaje que pueda hablar tanto con NIS2 como con la realidad de un equipo de TI sobrecargado.

2. De dónde viene todo esto

La estructura de la encuesta bebe de varias fuentes, todas ellas más respetables que un hilo en redes sociales:

- Los enfoques de madurez sectorial de ENISA (NIS360), que cruzan criticidad y capacidad para situar a los sectores en zonas de riesgo que exigen acción inmediata.[web:9][web:12]
- Las evoluciones del NIST Cybersecurity Framework y de la Risk Management Framework, que han ido desplazando el foco desde la pura tecnología hacia la gobernanza y la gestión integral del riesgo. [web:13]
- Los índices industriales que sacuden la complacencia, como el Cisco Cybersecurity Readiness Index 2025, que recuerda a muchos países y sectores que su madurez es bastante menos heroica de lo que pensaban.[web:1]

La encuesta no se limita a preguntar “¿lleva usted antivirus?”, sino que intenta entender si la organización ha interiorizado que la ciberseguridad es una cuestión de gobierno, economía, cultura y, ocasionalmente, de valentía política.

3. Qué pretende medir realmente

La encuesta se articula en bloques que, en conjunto, permiten construir un Índice Global de Madurez (IGM) y, con algo de trabajo extra, aproximaciones razonables del retorno de la inversión en ciberseguridad (ROI). Pero lo importante no son los números por sí solos, sino lo que insinúan:

- Si la alta dirección se toma la ciberseguridad como un asunto de negocio o como una molestia técnica.
- Si los riesgos se gestionan de manera sistemática o se improvisan a golpe de incidente.
- Si el cumplimiento normativo es un ejercicio litúrgico o un mecanismo de mejora real.
- Si la organización está haciendo algo parecido a Zero Trust o solo lo pronuncia en conferencias.
- Si, cuando llegue un incidente grave, habrá algo más que un PDF con un plan de respuesta.

La narrativa que subyace es sencilla: una organización madura en GRC no es la que no sufre ataques, sino la que sufre muchos, responde bien y aprende deprisa.

4. Por qué tanto énfasis en Zero Trust

En la encuesta se dedica un bloque completo a capacidades técnicas y Zero Trust, no por devoción al último lema del sector, sino porque la experiencia reciente (incluyendo los datos de 2025 sobre retrocesos de resiliencia de red en varios países europeos) muestra que las arquitecturas heredadas perimetrales no dan más de sí.[web:1] En un entorno de trabajo híbrido, nube ubicua y cadenas de suministro complejas, el viejo “confía en la red interna” es una invitación abierta al desastre.

Zero Trust, entendido sin dogma, es un criterio útil de madurez: obliga a pensar en identidad, contexto, segmentación, supervisión continua y menor privilegio. Las preguntas de la encuesta intentan discriminar entre quien ha comprado una solución de marketing “Zero Trust flavored” y quien ha rediseñado su arquitectura y su gobernanza en torno a estos principios.

5. El papel incómodo del cumplimiento

La encuesta también explora el grado de cumplimiento con marcos como NIS2, DORA, ENS o ISO 27001. No porque cumpliendo se garantice la seguridad (spoiler: no), sino porque el incumplimiento sistemático de normas sensatas es un indicador adelantado de problemas mayores.[web:9][web:12] [web:5]

Un ecosistema en el que las organizaciones cumplen solo cuando el regulador mira, o solo lo estrictamente necesario para pasar la auditoría, genera una falsa sensación de seguridad que se rompe con el primer incidente serio. Por eso se pregunta no solo qué normas se aplican, sino cómo se gestionan, revisan y traducen a controles vivos.

6. De la métrica al relato

La magia —si se le puede llamar así— ocurre cuando las respuestas se agregan y se proyectan sobre un mapa sectorial y nacional. De repente, se puede ver:

- Sectores con alta criticidad y baja madurez, donde la política pública debería ponerse nerviosa.
- Sectores que invierten mucho pero no consiguen mejorar su madurez, señal de problemas de gobierno o de diseño.
- Sectores que, con menos recursos, gestionan el riesgo de manera más inteligente.

Con ese material, un informe de resultados no tiene por qué ser un cementerio de gráficos: puede convertirse en un relato coherente sobre dónde estamos, qué estamos haciendo razonablemente bien y dónde estamos jugando con la suerte.

7. Una invitación a la honestidad

La encuesta está pensada para ser contestada con honestidad intelectual. No pretende demostrar que nadie es perfecto ni que todo está perdido, sino establecer una línea de base para mejorar. Si una organización descubre que está menos madura de lo que pensaba, no ha fracasado: ha ganado información.

El compromiso implícito es que los resultados agregados sirvan para orientar políticas, inversiones y cooperación, no para señalar con el dedo. En un país donde la economía, los servicios públicos y la vida cotidiana dependen crecientemente de sistemas digitales interconectados, tomarse en serio esa promesa es casi tan importante como configurar bien el firewall.

8. Y ahora, qué

Tras completar la encuesta, cada organización debería poder situarse en un mapa de madurez y, ojalá, responder a tres preguntas con menos conjeturas:

1. ¿Dónde estamos realmente en GRC de ciberseguridad?
2. ¿Qué deberíamos priorizar en los próximos 12–24 meses?
3. ¿Cómo explicamos esta realidad al consejo sin perder el sentido del humor?

Si esta herramienta ayuda, aunque sea un poco, a que esas conversaciones sean más informadas y menos defensivas, la encuesta habrá cumplido su función. El resto dependerá, como casi siempre, de la capacidad de decidir y de sostener esas decisiones en el tiempo.